Program Charter

AI Governance and Compliance Portfolio

PROJECT INTRO

FinanceGuard AI is a fine-tuned large language model supporting financial document review while processing PII and confidential financial data through an internal API gateway and hybrid-cloud environment. The portfolio supports an executive decision on continued deployment and scaling.

OVERVIEW

Develop an integrated governance package that connects accountability, responsible-AI gaps, ISO/IEC 42001 control alignment, and SOC 2 audit evidence. The final narrative is designed for CISO and steering-committee review.

METHODOLOGY

1. Establish a single system profile and risk assumptions.
2. Assign RACI ownership across the AI lifecycle.
3. Assess Microsoft Responsible AI principles and map gaps to ISO/IEC 42001 controls.
4. Evaluate SOC 2 evidence as Pass, Partial, or Fail.
5. Confirm cross-document consistency and formulate the executive decision.

OBJECTIVES

- Establish one accountable owner for each lifecycle decision.
- Identify and prioritize PII, monitoring, impact, security, and transparency gaps.
- Define audit-ready evidence and remediation exit criteria.
- Produce a defensible deployment recommendation with traceability across artifacts.

NAVIGATION

1. AI Governance RACI: ownership and escalation.
2. Governance Gap Analysis: responsible-AI deficiencies and remediation.
3. ISO/IEC 42001 Control Matrix: implementation status and audit artifacts.
4. SOC 2 Evidence Tracker: evidence sufficiency, residual risk, and CISO recommendation.
5. Evidence and Lessons Learned: sample artifacts, evaluation notes, and retrospective.

SCOPE

In scope: model governance, PII boundaries, hybrid-cloud oversight, monitoring, impact assessment, AI security, transparency, SOC 2 Security and Confidentiality evidence, exceptions, and executive risk acceptance.

Out of scope: model redevelopment, production configuration changes, legal opinions, independent certification, and live control testing.

SUCCESS CRITERIA

Exactly one Accountable role per lifecycle activity; consistent system assumptions; control ratings supported by evidence; audit findings traceable to governance gaps; enforceable remediation ownership; and a clear Go, Conditional Go, or No-Go decision.